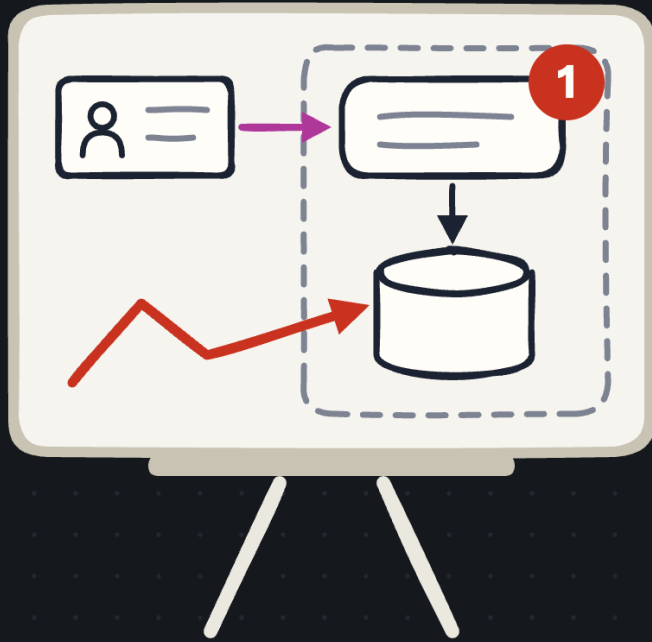




RUNTIME THREAT MODELING

ThreatViz Defend

Understand the threat while you vibe code.

hackUMBC 2026 · Ricky Chen, Mouhamadou Dieng, Jonathan Solomon

THE PROBLEM

Vibe coding ships apps nobody can explain

It works, so it ships.

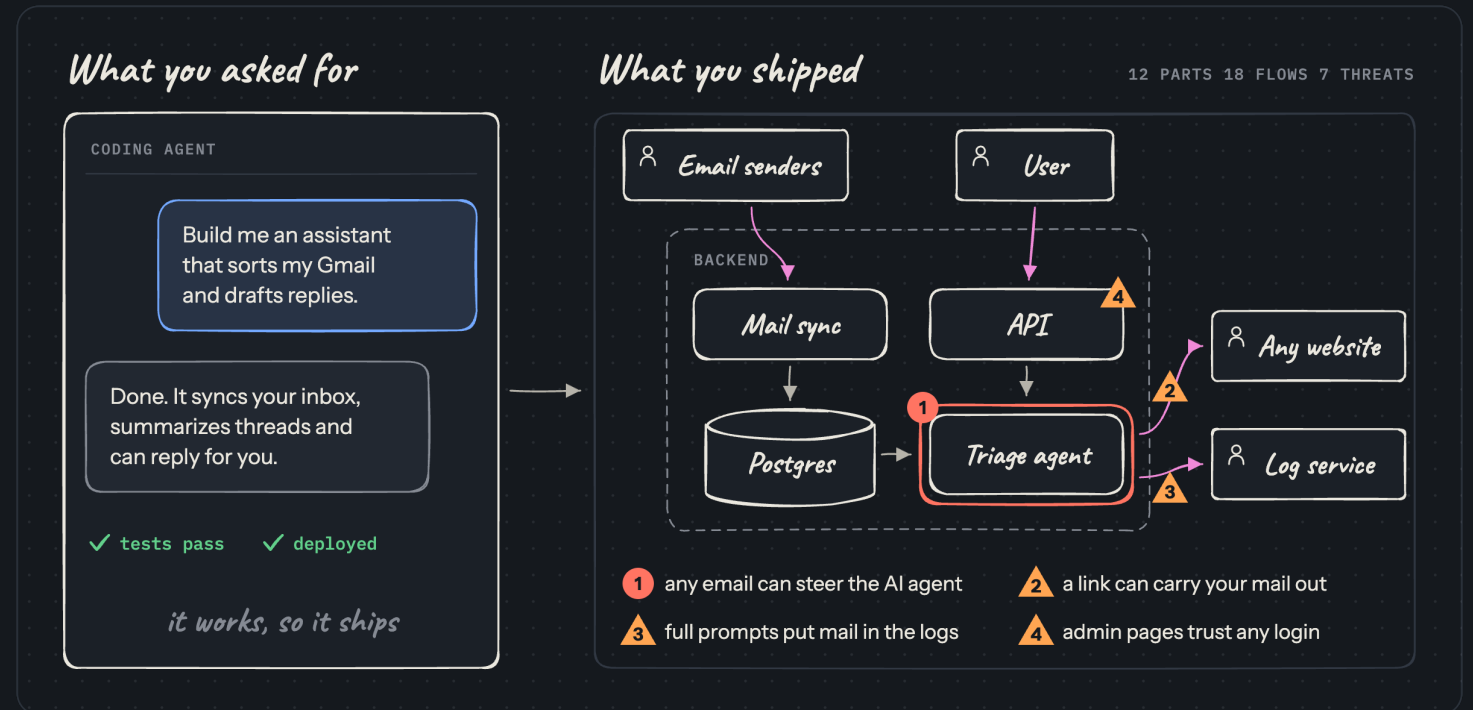
You describe it, a coding agent writes it, the tests pass.

No mental model.

Nobody can say which parts exist, where the data goes, or what trusts what.

Security needs that model.

Threat modeling and code review assume someone understands the design.



One real example board: a one-line prompt became 12 parts, 18 data flows and 7 threats.

WHAT IS THREAT MODELING

Know how it breaks before an attacker does

THREAT MODELING means mapping how a system works, where its data flows and what trusts what, then asking what can go wrong at each step and fixing the worst of it before it ships.

THE FOUR QUESTIONS, FROM THE THREAT MODELING MANIFESTO

1 What are we working on?

2 What can go wrong?

3 What are we going to do about it?

4 Did we do a good enough job?

STANDARDS WE BUILD ON

STRIDE

Microsoft's six threat categories, checked by rules on every part of the map.

OWASP

The Threat Modeling Cheat Sheet for map review, and the Top 10 for LLM Applications 2025 on AI parts.

CWE

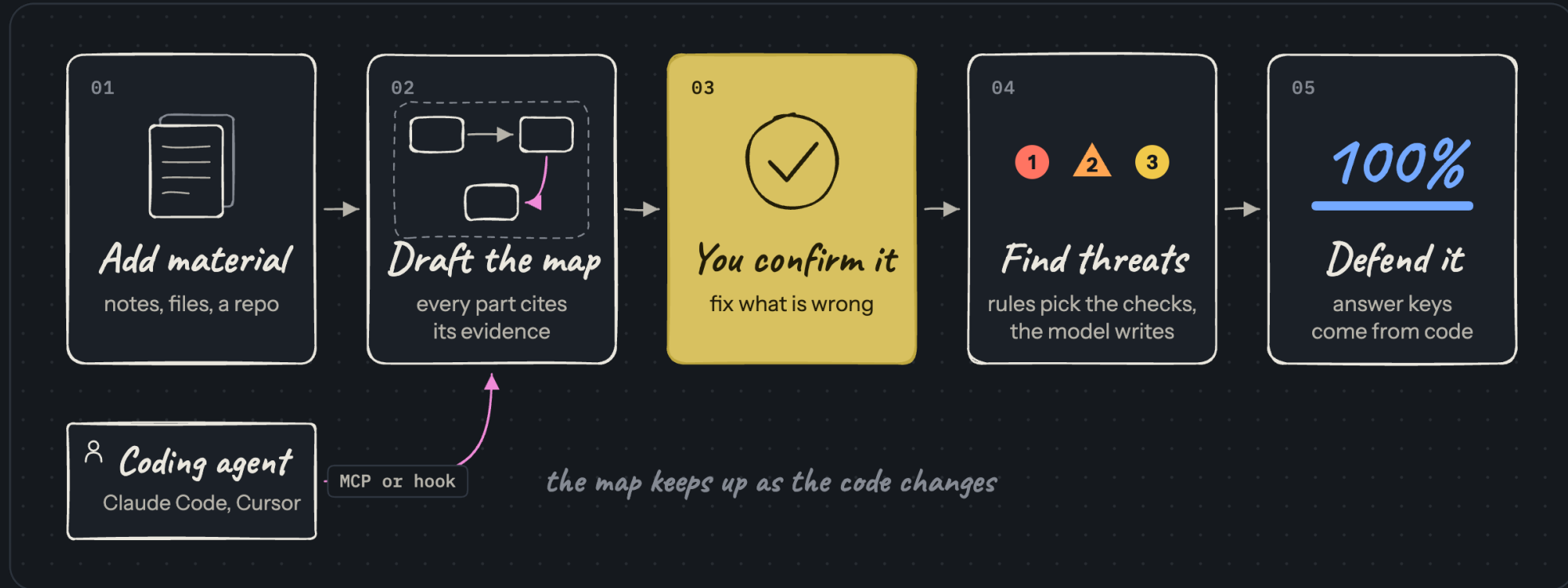
Threats link to CWE and OWASP ids, and only ids the model is sure of. No guesses.

NIST SSDF

Practice PW.1.1 calls for threat modeling during design. ThreatViz puts it in every developer's hands.

OUR SOLUTION

Build the mental model, then check that it stuck



Static or runtime.

Paste a repo, or a Claude Code or Cursor hook sends each git diff.

Coverage from code.

STRIDE, trust boundaries and the lethal trifecta. The model writes the top 5 to 8 threats.

Understanding, checked.

Up to 7 questions on your own map. Answer keys come from code. Text or voice.

30-SECOND DEMO

From vibing to knowing your threats ahead of disaster

Everyone is vibing. Know the risks before a stakeholder asks or an attacker finds them.

claude · ~/inbox-helper

* Welcome to Claude Code
cwd: ~/inbox-helper

L MCP threatviz · connected · 7 tools

L Hook ThreatViz runs when a turn ends

> Build an assistant that syncs my Gmail, triages mail with an AI agent and drafts replies

I'll set up an API, a mail sync worker, a Redis job queue and a triage agent on OpenAI tool calling.

Write(api/main.py)
L Wrote 142 lines

Write(worker/sync.py)
L Wrote 96 lines

Write(agent/triage.py)
L Wrote 118 lines

Write(docker-compose.yml)
L Wrote 34 lines

Done. 14 files changed, tests pass.

L ThreatViz hook posted git diff · 14 files → board "Inbox Helper"

>

? for shortcuts threatviz · MCP

ThreatViz Defend Inbox Helper Ready to defend Claude Code connected

Threats 4 Defend

← All threats

1 Critical Elevation of privilege

A malicious email takes over the triage agent
on Triage agent

Anyone can email instructions that the agent follows, like forwarding private mail to the sender.

FIX FIRST
Turn off auto-send and fence the agent's tools.

EVIDENCE
"Anyone can email a user, so message bodies are untrusted."

4 Rules pick what to check. The top threats pin to the parts they hit.

- 1 Vibe code.**
Claude Code builds the app, connected over MCP.
- 2 Git diff hook.**
Each architectural change posts to the board.
- 3 Threat model.**
The map draws, you confirm it, threats pin to parts.
- 4 Defend it.**
Answer by text or voice. Backboard remembers.

The map keeps up while your agent codes



OVER MCP, THE AGENT CAN

- List your boards and read the map and threats
- Describe any part and ask the board a question
- Report a change on demand
- Ask you the Defend questions in the editor

WHAT STAYS ON YOUR MACHINE

- Secret files are filtered from both sides of the diff
- Credential-shaped values are masked, then masked again on the server
- The token goes only to the API address you set, never one from a committed file

Reading a report is not understanding it

Question 1 of 7

TRUST BOUNDARIES

Which of these flows cross a trust boundary, where the receiving side has to check who sent the data?

Pick every one that applies.

A

Gmail API to Mail sync worker: new mail

B

User to Web app: sign in, review

A real question from the Inbox Helper board.

1

Questions from your own map.

Which flows cross a boundary, who reads sensitive data, where the worst threat hits. Code computes every key.

2

Open answers, graded with evidence.

A model grades your own words against the map and explains every miss.

3

Talk it through.

An ElevenLabs voice coach asks out loud, and dictation takes spoken questions.

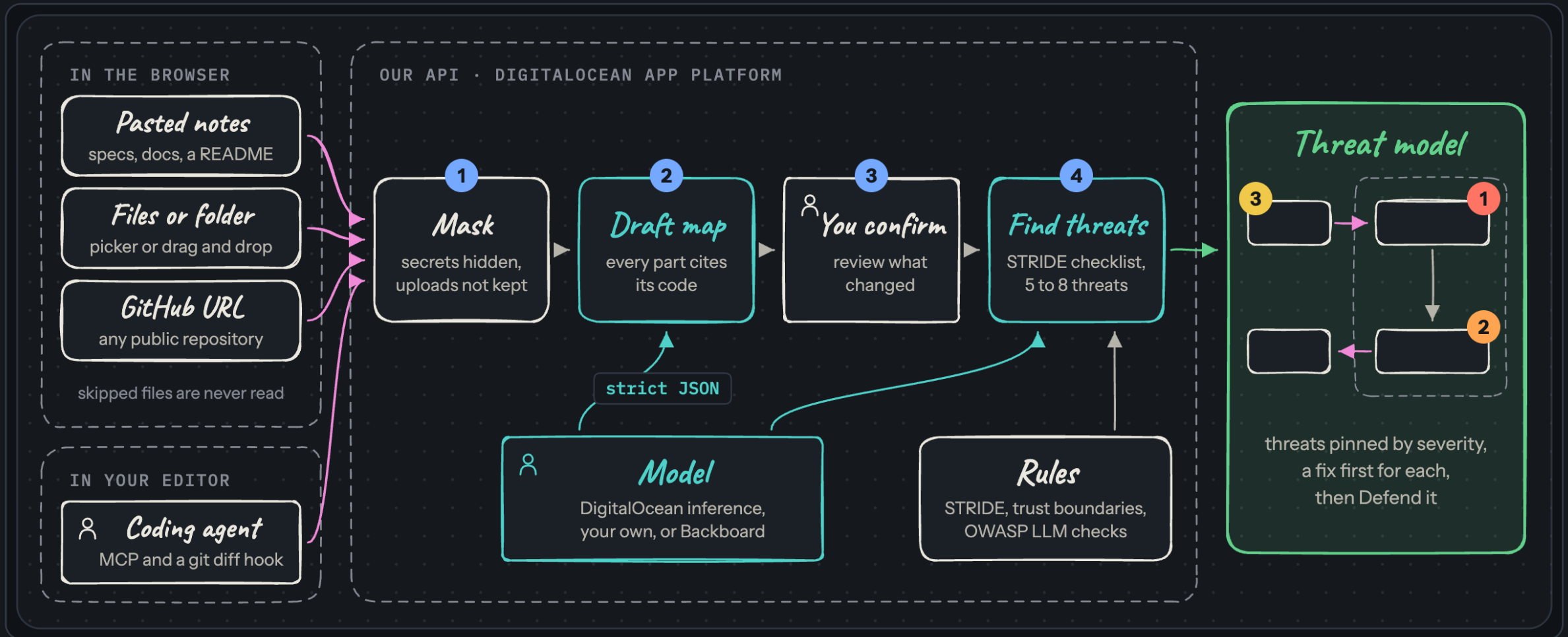
4

Backboard remembers.

Before grading, it recalls what you missed in earlier sessions, then keeps a new note.

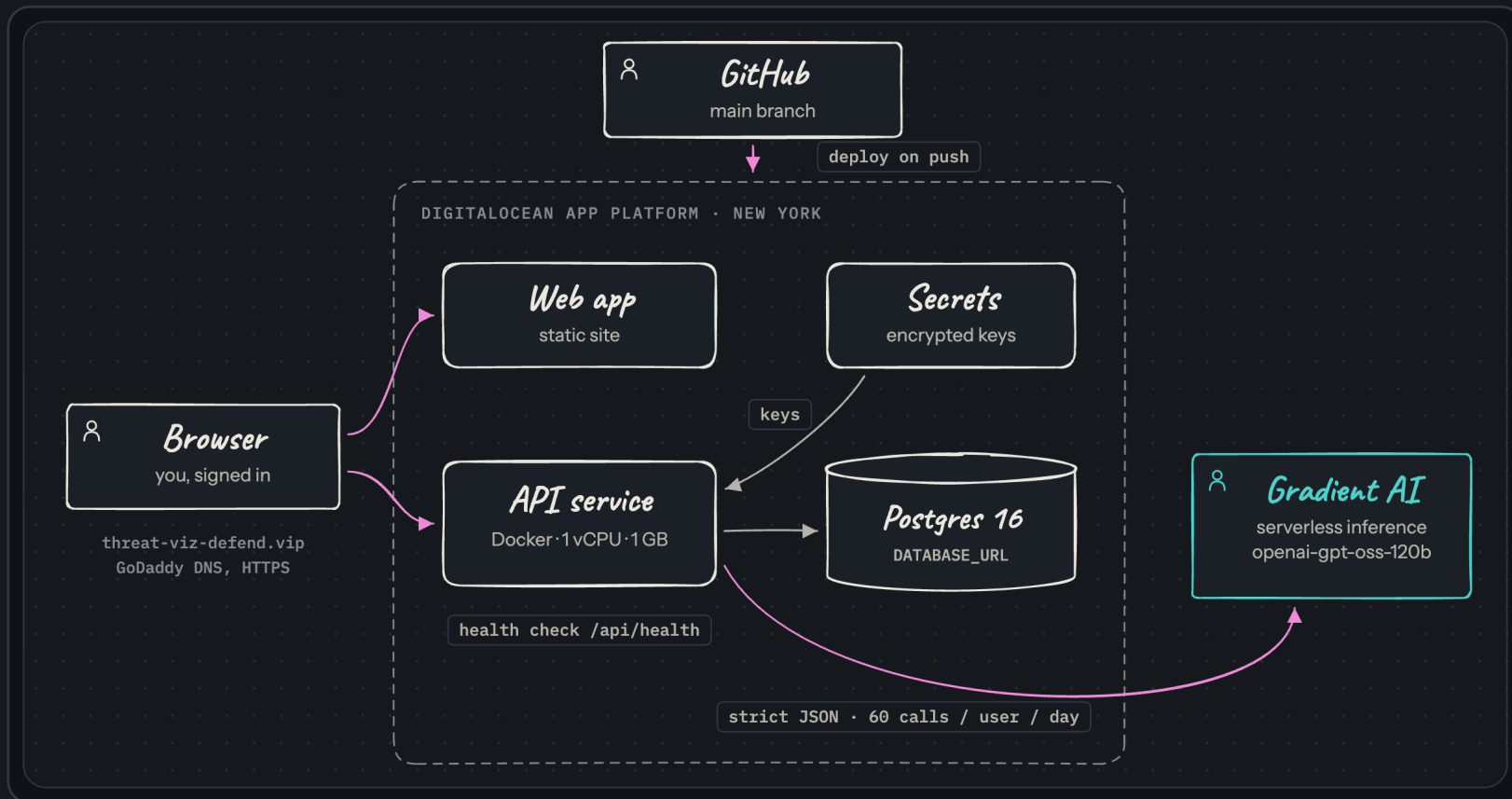
HOW IT'S BUILT

Anything you bring becomes a threat model



One API owns every rule and model call. The browser only draws what it returns, so editing the page cannot change a threat.

One App Platform spec runs the whole product



One spec, two components.

The API as a Docker service and the static web app, in New York.

Deploy on push.

Every merge to main rebuilds both, behind a health check.

Gradient AI inference.

The default model, openai-gpt-oss-120b, runs on DigitalOcean too.

Secrets and budgets.

Encrypted keys, 60 model calls per user a day, 300 accounts.

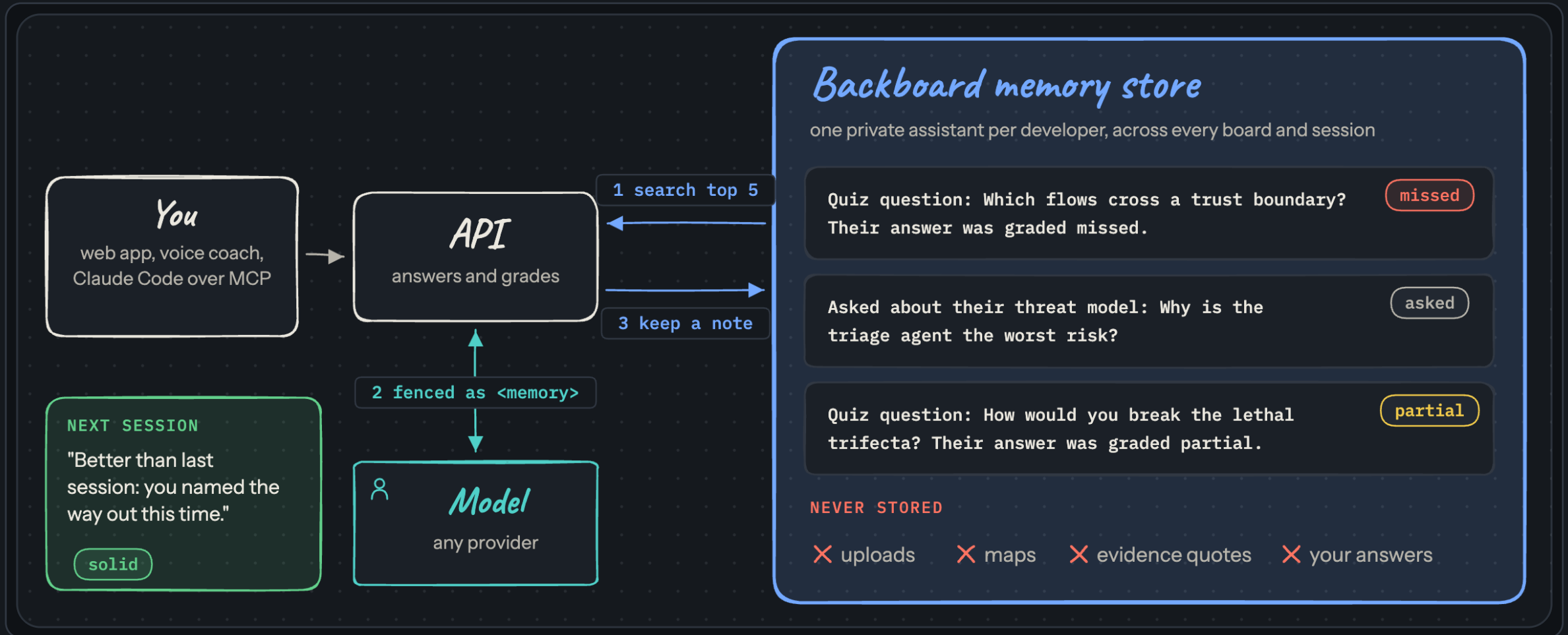
Every deploy, board and analysis runs on DigitalOcean.

Defend your threat model out loud



The key stays on our server. The browser holds a one-conversation token, and each user gets a daily voice budget.

A memory store that remembers what you missed



Or route every model call through Backboard. Mapping only reads memory, while answers and grades write it.

Every developer can defend what they ship

1

Threat modeling for everyone.

Runs on any codebase in minutes, no security team needed.

2

Trains the defender.

The person who ships the code can explain how it breaks.

3

Keeps up at runtime.

Every agent change redraws the map and waits for review.

4

Secure by design.

Defensive only. Our own model has no tools and its output is plain text.

BUILT WITH

DigitalOcean App Platform, Postgres 16, Gradient AI inference

ElevenLabs Voice coach and speech to text

Backboard Memory of what you missed, across sessions

GoDaddy Our domain

MCP Claude Code and Cursor integration

WHAT'S NEXT

From a hackathon demo to a pull request check

Pull request check

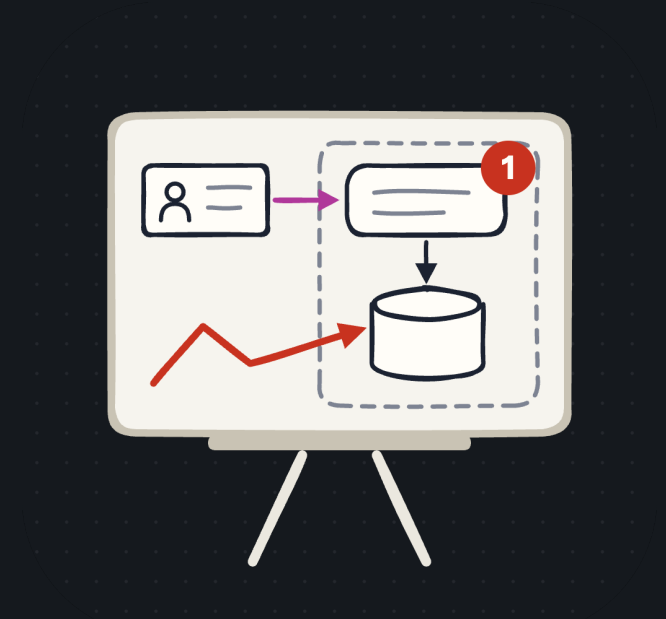
Flag a change that adds a boundary crossing, an AI tool or a lethal trifecta before it merges.

Team view

See which threats each teammate can explain, and which ones nobody can.

Private repositories

Import private code through a GitHub app.



Thank you

github.com/HackedRico/threat-viz-defend